

Manual 27 — Data Governance & Privacy Engineering Controlled Implementation

Controlled English master — release candidate source

****Series order:**** 27

****Published NIST framework baseline:**** NIST Privacy Framework 1.0

****Change-watch:**** NIST Privacy Framework 1.1 Initial Public Draft / forthcoming final

****Privacy-engineering reference:**** NISTIR 8062

****Boundary:**** This manual is implementation guidance, not legal advice, regulator approval, certification, or a substitute for jurisdiction-specific law.

01. Purpose, scope, and boundaries

Define enterprise data-governance and privacy-engineering practices without conflating guidance with jurisdiction-specific legal obligations.

02. Source hierarchy and change control

Separate laws/regulations, regulator guidance, NIST Privacy Framework, privacy-engineering guidance, contracts, policy, and internal standards.

03. Data governance operating model

Define councils, stewards, custodians, owners, privacy, security, legal, records, architecture, and business-accountability roles.

04. Data inventory and lineage

Maintain authoritative inventories of data domains, systems, flows, stores, processors, transfers, and lineage relationships.

05. Classification and handling

Establish classification criteria, handling rules, access conditions, sharing limits, protection requirements, and evidence.

06. Purpose specification and use limitation

Record approved business purposes, compatible uses, restrictions, owners, review triggers, and exceptions.

07. Data minimization

Collect, create, retain, and expose only data proportionate to defined purposes and obligations.

08. Data quality and accuracy

Define quality dimensions, validation, correction, ownership, monitoring, and issue-management controls.

09. Retention and deletion

Implement retention schedules, legal holds, deletion, archival, disposal, exceptions, and evidence of execution.

10. Access governance

Apply least privilege, role/attribute-based controls, privileged access, periodic review, segregation, and revocation.

11. Data sharing and disclosure

Control internal and external sharing through authorization, agreements, purpose restrictions, minimization, logging, and review.

12. Cross-border and jurisdictional data flows

Maintain legal/contractual transfer assessments and avoid assuming a single global transfer mechanism applies everywhere.

13. Privacy risk assessment

Identify privacy harms, affected individuals, likelihood, severity, mitigations, residual risk, and reassessment triggers.

14. Privacy engineering objectives

Translate privacy goals into system properties such as predictability, manageability, disassociability, control, and transparency.

15. Privacy by design and default

Embed privacy requirements into architecture, SDLC, procurement, change management, and default configurations.

16. Consent and preference management

Where applicable, govern notices, choices, consent state, withdrawal, preference propagation, evidence, and exceptions.

17. Individual rights operations

Support access, correction, deletion, portability, objection, restriction, and other applicable rights with jurisdiction-aware workflows.

18. Identity and sensitive-data protection

Apply stronger governance for identifiers, credentials, health, financial, biometric, precise-location, children's, and similarly sensitive data as applicable.

19. De-identification and pseudonymization

Define approved techniques, re-identification risk assessment, controls, testing, contracts, and use restrictions.

20. Privacy-enhancing technologies

Evaluate encryption, tokenization, secure computation, differential privacy, federated techniques, synthetic data, and other PETs proportionate to risk.

21. Logging, monitoring, and observability

Log access, sharing, deletion, consent state, rights requests, policy exceptions, and material data-flow changes.

22. Third-party data governance

Assess processors/vendors, instructions, sub-processing, evidence, security/privacy controls, retention, deletion, and incident obligations.

23. Cloud and data-platform governance

Govern data lakes, warehouses, SaaS, analytics platforms, object stores, APIs, notebooks, and cross-account sharing.

24. Analytics and secondary use

Review new analytics, enrichment, inference, profiling, and reuse for purpose compatibility, privacy risk, fairness, and transparency.

25. Records and evidence architecture

Maintain decisions, assessments, approvals, mappings, exceptions, notices, contracts, logs, issue records, and remediation evidence.

26. Incident and breach coordination

Integrate data governance with security/privacy incident detection, containment, assessment, notification, recovery, and lessons learned.

27. Metrics and indicators

Track inventory coverage, data quality, rights performance, retention execution, access review, privacy risk, vendor issues, and remediation aging.

28. Training and role competence

Provide role-based training for owners, stewards, engineers, analysts, privacy, security, procurement, and leadership.

29. Assurance and testing

Test governance design and operation through sampling, control validation, technical testing, rights-request review, and evidence inspection.

30. Management review

Review performance, regulatory change, incidents, privacy risk, metrics, exceptions, resources, and improvement priorities.

31. Continual improvement

Use findings, incidents, complaints, audit results, technology change, and regulatory change to drive controlled improvements.

32. Release and implementation roadmap

Package Essential / Structured / Enhanced implementation paths with source verification, localization, accessibility, provenance, checksums, workflow-security, human-review evidence where required, and sequential release controls.